

HIPAA and Production Readiness Plan for NodeOnFHIR Chronicle Workstation

Executive view

Assuming your stated product direction is a workstation-class Chronicle Workstation sold to clinicians or clinics, with patient data stored under the customer's control and **no Orbital-hosted PHI environment**, that is a materially cleaner HIPAA posture than a managed cloud or hosted SaaS model. HHS states that **merely selling software does not create a business associate relationship if the vendor does not have access to the customer's PHI**; by contrast, HHS also states that an entity that **stores or maintains ePHI on behalf of** a covered entity is a business associate even if the data are encrypted and the vendor lacks the key. In practice, that means Orbital's biggest legal risk is not "getting BaseEHR certified" or "keeping a Book of Evidence"; it is accidentally crossing the line into **accessing, maintaining, backing up, syncing, or receiving PHI** through telemetry, support workflows, cloud sync, hosted messaging, or remote administration. ¹

Your current understanding of HIPAA as "user accounts, encryption at rest / in transit, an audit log, and a book of evidence" is **directionally right but materially incomplete**. The HIPAA Security Rule also requires risk analysis and risk management, workforce security and training, incident procedures, contingency planning, evaluation, workstation and device/media controls, authentication, access management, and documentation retention. The Privacy Rule separately requires training, safeguards, complaint handling, sanctions, mitigation, and six-year documentation retention, and it gives individuals rights around access and accounting of disclosures. Addressable specifications are **not optional**; all Security Rule standards apply, and addressable items must either be implemented or replaced with a documented reasonable alternative. ²

For NodeOnFHIR specifically, the most important conclusion is that the current `hipaa-compliance` package is a useful starting point, but it is **not yet production-ready as a coherent compliance subsystem**. The codebase already has the right instincts—FHIR-oriented audit logging, collection hooks, encryption utilities, policy templates, reports, and settings scaffolding—but there are architectural inconsistencies and control gaps that would undermine both HIPAA evidence and ONC-style audit assertions if left unresolved. The biggest blocker is that the package appears to be split between **two audit stores**: the logger writes to the core `AuditEvents` collection, while reporting, export, publications, and encryption methods largely read from `HipaaAuditLog`. ³

What HIPAA actually requires for this product model

For a workstation-first clinician product, the governing legal frame is broader than technical controls alone. Under the Security Rule, covered entities and business associates must ensure the confidentiality, integrity, and availability of ePHI; protect against reasonably anticipated threats and impermissible uses/disclosures; and ensure workforce compliance. The Rule is intentionally flexible and technology-neutral, so it does not

prescribe one exact architecture, but it does require a documented, risk-based choice of controls that matches the product's size, complexity, capabilities, and risks. That flexibility works in your favor for a workstation-class product, but it also means you need **documented reasoning** for why the chosen local architecture, local storage, update process, support model, and endpoint safeguards are reasonable and appropriate. ⁴

At the code-and-product level, the Security Rule's technical safeguards require access control, unique user identification, emergency access procedures, audit controls, integrity protection, authentication, and transmission security. Automatic logoff and encryption/decryption are listed as addressable under the access-control standard, and integrity controls and transmission encryption are addressable under other parts of the Rule—but again, “addressable” does not mean optional. For a workstation product that intentionally stores health information locally, local encryption becomes not just prudent HIPAA engineering but also closely aligned with ONC's end-user device encryption criterion for certified health IT. ONC's certification rules likewise expect immutable and tamper-detectable audit logs and sortable audit reports. ⁵

The administrative and physical pieces matter just as much for your customer-facing “user Book of Evidence.” HIPAA requires risk analysis, risk management, security awareness training, incident procedures, contingency planning, periodic evaluation, workstation use/security, and device/media controls; the Privacy Rule adds workforce training, safeguards against impermissible use/disclosure, complaint documentation, sanctions documentation, mitigation, and policy/document retention. The statutory term is not “Book of Evidence,” but the legal effect is close: HIPAA requires the covered entity or business associate to **maintain written or electronic policies, procedures, and records of required actions/assessments**, and to retain those records for six years. ⁶

The Privacy Rule's accounting-of-disclosures requirement is more specific than many training programs make it sound. An individual may request an accounting covering the prior six years, the covered entity generally must respond within 60 days, and the accounting must include the date, recipient, brief description of the PHI, and purpose/basis of the disclosure. But HIPAA **excludes** several categories from this accounting requirement, including disclosures for treatment, payment, and health care operations, disclosures to the individual, incidental disclosures, and disclosures pursuant to authorization. That means you should distinguish between **internal access auditing** and **disclosure accounting** in the product model instead of treating every patient access event as the same thing. ⁷

That distinction matters for your workstation architecture. A clinician selecting a patient in the UI, opening a chart, or searching for records can be an auditable internal access event for Security Rule and ONC purposes, but it is not automatically an accounting-of-disclosures event under HIPAA. By contrast, outbound secure messaging, document export, Direct transmission, fax/email handoff, print/download, or submission to a third party may be a disclosure event and should be recorded with recipient, purpose/legal basis, and payload description. The FHIR `AuditEvent` resource and IHE Basic Audit Log Patterns are well suited to representing both ordinary read/query/update events and privacy-disclosure events in a standards-based way. ⁸

Finally, for any direct-to-patient version, there is an additional non-HIPAA issue. If the product is offered as a consumer-controlled personal health record or related health app outside HIPAA, the FTC's Health Breach Notification Rule may apply to vendors of personal health records, PHR-related entities, and certain service providers. So a “not HIPAA” product variant is not necessarily a “not regulated” product variant. ⁹

What the current package already does well

The `@node-on-fhir/hipaa-compliance` package already covers a meaningful amount of ground. Its README describes automated audit logging, FHIR-compliant audit events, collection hooks, reporting, policy management with more than 20 templates, role-based access concepts, real-time monitoring, configurable retention, and Nightwatch tests. The package also exposes routes for an audit-log page and policy pages, and it defines a taxonomy of event types including view/read/access, create/update/delete, login/logout, denied/error, and export/print/download. That is a sensible foundation for both HIPAA-style audit controls and ONC-oriented audit/reporting features. ¹⁰

The package also has several concrete implementation assets that are genuinely useful. It defines a `HipaaAuditLog` schema with user, patient, resource, session, IP, user agent, metadata, encryption level, and signature fields; it includes server hooks for insert/update/remove and optional find/read logging; it offers report generation and export in CSV/JSON/FHIR-like formats; and it includes an `EncryptionManager` with field-level encryption helpers and signature generation/verification helpers. The settings template already anticipates audit feature flags, hook configuration, retention years, secondary-auth toggles, export limits, and monitoring options. ¹¹

The policy surface is also broader than a simple placeholder binder. The package includes policy routes and actual markdown templates for auditing, breach response, risk management, data integrity, data retention, system access, incident response, roles, device/media handling, facility access, and more. There is also a mapping document tying HIPAA sections to policy artifacts. For creating Orbital's manufacturer/OEM evidence pack, these files are valuable raw material—even though they need substantial adaptation for your workstation deployment model. ¹²

The package is also already aware of ONC-oriented audit expectations. The workflow metadata explicitly describes the audit log route as tied to ONC §170.315(d)(2), (d)(3), and (d)(10), and the README claims compliance coverage for access logging, audit controls, integrity, authentication, and transmission security. That makes the package a reasonable place to consolidate HIPAA, ONC, and local workstation evidence, provided the current split-brain architecture is fixed. ¹³

Gap analysis and production blockers

The single largest blocker is the package's **inconsistent audit architecture**. `HipaaLogger.logEvent()` writes to `global.Collections?.AuditEvents`, and startup indexing also targets the core `AuditEvents` collection, while many reporting, publication, export, integrity, and encryption paths continue to query or publish `HipaaAuditLog`. As written, the package appears capable of logging into one collection and reporting from another, which would make audit reports incomplete, disclosure accounting unreliable, and ONC/HIPAA evidence internally inconsistent. For production, you need one authoritative audit event store and one clearly defined projection/reporting layer. ¹⁴

A second blocker is **authorization and control-path fragility**. `SecurityValidators.canViewAuditLog()` returns `true` for any authenticated user if the `alanning:roles` package is unavailable, which is a fail-open posture for sensitive audit data. There also appears to be an authorization defect in patient-specific audit viewing: `canViewPatientAudits()` delegates to helper functions that are asynchronous on the server, but publications call the validator

synchronously. That creates a real risk—inference based on the code—that clinician/patient authorization checks may evaluate incorrectly. The settings model also shows path drift: the development template stores secondary-auth and timeout values in locations that do not cleanly line up with where validators and policy generation read them. ¹⁵

A third blocker is **control-quality mismatch** in encryption and audit immutability. The `EncryptionManager` falls back to a hard-coded insecure default key if no key is configured, offers a “basic” mode that is only Base64, and derives AES keys using a fixed salt string. Separate from that, the package describes audit logs as immutable and blocks updates/deletes on `HipaaAuditLog`, but the re-encryption method updates existing records directly. For ONC-style tamper resistance and production HIPAA evidence, audit events need either append-only semantics or a carefully controlled re-key/projection strategy that preserves historical verification and tamper evidence. ¹⁶

A fourth blocker is that the **policy system is not yet coherent for your product model**. The policy templates and mapping files are clearly inherited from Catalyze’s cloud/PaaS program and still refer to Catalyze, PaaS customers, VPN access to hosted systems, Apple laptops, cloud logging services, BAAs, and hosted environments. The package even includes “HIPAA inheritance for PaaS customers” documents, which is the opposite of your stated “no Orbital-hosted PHI” direction. On top of that, the server policy loader looks for files under `packages/hipaa-compliance/client/policies`, while the current repository path is `npmPackages/hipaa-compliance/client/policies`, and the policy generator’s variable names do not match some template placeholders like `{{getCompanyName}}`. Those issues make the current Book of Evidence generator unreliable without refactoring. ¹⁷

A fifth blocker is **scope coverage**. The current package is strongest on CRUD-style logging and policy display, but HIPAA production readiness also needs a documented risk-analysis workflow, sanctions/training records, complaints and mitigation records, incident and breach handling artifacts, contingency/backup/restore evidence, workstation use guidance, media disposal evidence, and a structured accounting/disclosure workflow. The policy templates hint at some of this, but the code package does not yet appear to implement these as first-class operational records or exportable evidence objects. That is the difference between a demo compliance package and one that can support a clinic’s actual audit or investigation. ¹⁸

Target architecture and the two Books of Evidence

The cleanest target state is to make **FHIR `AuditEvent` the canonical audit store** across the platform. The current logger already points in that direction by writing to the core `AuditEvents` collection, and the broader platform already uses FHIR-oriented packages such as `secure-messaging` and `pacio-core`. FHIR itself describes `AuditEvent` as a record of events relevant to operations, privacy, security, maintenance, and performance analysis, and IHE BALP layers reusable patterns for patient reads, queries, updates, deletes, and privacy disclosures. For production, keep one canonical `AuditEvent` pipeline, then build derived views for the UI, report generation, disclosure accounting, and evidence exports. ¹⁹

In that model, you should separate events into three logical classes even if they all serialize as `AuditEvent`. The first class is **internal access and operational events**: login, logout, failed auth, read, query, create, update, delete, export, print, privilege changes, audit-configuration changes, encryption-status changes, and break-glass use. The second class is **privacy disclosure events**: outbound Direct messages, patient-sharing actions, external exports, transmissions to another organization, print/download

for release, and similar disclosures. The third class is **compliance administration events**: training completion, policy acknowledgment, complaint intake/disposition, sanction issuance, incident closure, backup-restore test results, and risk acceptance decisions. This gives you one audit substrate and two practical books: a software-manufacturer evidence book and an operator/customer evidence book. ²⁰

For **Orbital Health Systems' OEM/manufacture Book of Evidence**, the right contents are the things Orbital actually controls: system architecture and product boundary statements; threat model and data-flow diagrams proving no Orbital-hosted PHI path by design; secure default settings; endpoint encryption expectations; release and signing procedures; SBOM/dependency review; V&V and E2E evidence; audit/tamper-detection tests; change management/CAPA; support SOPs that prohibit receiving PHI in tickets, logs, or telemetry; and mappings from product features to HIPAA and ONC criteria. This is not about pretending Orbital is a covered entity; it is about proving the product is engineered to support regulated customers without making Orbital the custodian of their PHI. That approach is consistent with HHS's software-vendor guidance, and it preserves a strong line between OEM responsibilities and customer operations. ²¹

For the **customer's HIPAA audit/evidence book**, the contents have to reflect what the clinician or clinic actually controls: risk analysis and risk-management decisions; workforce roster, access approvals, and role changes; training completion; sanctions records; complaint and mitigation logs; workstation inventory and placement; device/media disposal records; backup/restore test results; incident and breach logs; patient access/accounting requests and responses; and disclosures data. Some of these can be auto-generated by Chronicle, but several will always require customer-side attestations and records. That is normal under HIPAA, because many obligations are administrative and physical, not purely technical. ²²

On your specific design question about where to instrument events, the best answer is **server-side business actions first, client-side context second**. A future `Session.setWithAudit()` could be useful for recording user context changes like `selectedPatient`, especially for usability diagnostics or "context switched to patient X" signals, but it should not be the authoritative record for HIPAA or ONC audit purposes because the current `SessionExtensions` layer is just a client helper and not a tamper-resistant server event source. By contrast, outbound `secure-messaging` sends, PACIO document export/share actions, actual read/query operations, and privilege/configuration changes should emit canonical server-side `AuditEvent` records. A generalized `CollectionExtensions` audit wrapper is less attractive than method/publication interceptors plus explicit event emitters, because most of the legally meaningful actions are not simple collection mutations. ²³

Your "privacy screen blur" idea fits as a **reasonable optional workstation safeguard**, not as a core legal requirement. HIPAA requires workstation use/security safeguards and reasonable safeguards against impermissible and incidental disclosures, so privacy filters, obscuring PHI on inactivity, screen-lock overlays, and blurred patient banners in public settings are good optional controls where the risk analysis supports them. They belong in the workstation-hardening profile and customer guidance, not in the minimal legal kernel. ²⁴

Claude Code implementation plan

The first Claude Code workstream should be **architecture consolidation**. Make `AuditEvent` the only authoritative audit store; refactor `HipaaLogger`, reports, publications, exports, encryption/integrity

checks, and UI pages to read from that one source; and keep `HipaaAuditLog` only as a compatibility alias or remove it entirely. In the same pass, fix authorization so audit access is fail-closed, correct the async authorization bug risk in patient-audit checks, and normalize all settings paths so secondary authentication, session timeout, export approval, and related controls are read from one canonical schema. This phase is the prerequisite for every later evidence claim. ²⁵

The second workstream should be **event model expansion**. Define a platform-wide `AuditEvent` emitter API with explicit event families such as `access.read`, `access.query`, `access.denied`, `auth.login`, `auth.logout`, `security.config-changed`, `security.key-rotation`, `privacy.disclosure`, `privacy.accounting-response`, `ops.training-complete`, and `ops.policy-ack`. Emit these from server methods, publications, `secure-messaging` send/read flows, PACIO export/share flows, chart export/print/download actions, role changes, and break-glass/emergency-access flows. Use BALP and FHIR `AuditEvent` patterns where possible so report shape and search parameters stay standards-friendly. ²⁶

The third workstream should be **privacy-disclosure accounting**. Build a derived disclosure ledger on top of canonical audit events, not a separate ad hoc log. For each disclosure candidate, capture the date, recipient, recipient address or organization, patient, PHI summary, purpose/legal basis, operator, channel, and final delivery state. Then implement a rules layer that marks whether the event is included in HIPAA accounting under §164.528 or excluded because it falls under treatment, payment, health care operations, authorization, or another listed exception. If you ever decide to pursue ONC §170.315(d)(11), this same subsystem can also support the broader ONC disclosure-recording requirement for treatment, payment, and health care operations. ²⁷

The fourth workstream should be **endpoint and workstation hardening for the local-storage model**. Chronicle should ship with documented expectations and evidence hooks for full-disk encryption, local account uniqueness, inactivity timeout/automatic logoff, local backup/restore validation, token/credential protection, no-PHI telemetry defaults, and secure update/signing. For ONC-aligned builds, document how local end-user device encryption is satisfied, how audit cannot be disabled except by limited users if at all, and how tamper detection works. For Orbital's "no servers with PHI" goal, disable or aggressively redact crash logs, cloud diagnostics, screenshots, and support bundles by default so Orbital does not become a recipient of PHI by accident. That last point is an inference from HHS's access/maintenance guidance, but it is exactly the kind of engineering boundary that preserves your desired legal posture. ²⁸

The fifth workstream should be **evidence generation and policy refactoring**. Replace the inherited Catalyze/PaaS language with Orbital/Chronicle workstation language, remove hosted-cloud inheritance assumptions, fix the policy loader path, and normalize template variables so the generator actually fills company and environment data. Then define two exportable evidence bundles: an OEM bundle for Orbital and an operator bundle for the clinician customer. The OEM bundle should include release metadata, test evidence, signing evidence, risk treatment decisions, and product control mappings. The operator bundle should include local provisioning records, training, sanctions, complaints, incidents, backup/restore tests, disclosures, and request-response logs for patient rights. ²⁹

The sixth workstream should be **verification and production acceptance**. Expand E2E and V&V coverage so test evidence proves not only CRUD logging but also read/query logging, denial logging, disclosure logging, policy acknowledgments, privilege changes, audit export, tamper detection, and document/accounting response generation. ONC's audit criteria emphasize immutable, tamper-detectable logs and

sortable audit reports, while HIPAA requires periodic evaluation and documentation updates in response to operational/environmental change. Your continuous-improvement posture is the right moment to convert these expectations into regression gates and release blockers. ³⁰

In short, the package should evolve from a UI-and-template-centric compliance add-on into a **canonical audit and evidence subsystem** for a workstation-first EHR. If you keep Orbital out of the PHI custody path, standardize on server-side FHIR `AuditEvent`, distinguish internal access from external disclosure, and generate separate OEM and customer evidence books, you can support clinician HIPAA operations without unnecessarily turning Orbital into a hosted PHI operator. ³¹

¹ ²¹ ³¹ Is a software vendor a business associate of a covered ...

https://www.hhs.gov/hipaa/for-professionals/faq/256/is-software-vendor-business-associate/index.html?utm_source=chatgpt.com

² ⁶ ²² 45 CFR 164.308 -- Administrative safeguards.

https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308?utm_source=chatgpt.com

³ ¹⁰ raw.githubusercontent.com

<https://raw.githubusercontent.com/node-on-fhir/core/main/npmPackages/hipaa-compliance/README.md>

⁴ 45 CFR 164.306 -- Security standards: General rules.

https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.306?utm_source=chatgpt.com

⁵ eCFR :: 45 CFR 164.312 -- Technical safeguards.

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312>

⁷ ²⁷ eCFR :: 45 CFR 164.528 -- Accounting of disclosures of protected health information.

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-E/section-164.528>

⁸ ²⁰ ²⁶ AuditEvent - FHIR v6.0.0-ballot4

https://build.fhir.org/auditevent-definitions.html?utm_source=chatgpt.com

⁹ Complying with FTC's Health Breach Notification Rule

https://www.ftc.gov/business-guidance/resources/complying-ftcs-health-breach-notification-rule-0?utm_source=chatgpt.com

¹¹ raw.githubusercontent.com

<https://raw.githubusercontent.com/node-on-fhir/core/main/npmPackages/hipaa-compliance/lib/Collections.js>

¹² raw.githubusercontent.com

<https://raw.githubusercontent.com/node-on-fhir/core/main/npmPackages/hipaa-compliance/lib/PolicyRoutes.js>

¹³ raw.githubusercontent.com

<https://raw.githubusercontent.com/node-on-fhir/core/main/npmPackages/hipaa-compliance/workflow.json>

¹⁴ ¹⁹ ²⁵ raw.githubusercontent.com

<https://raw.githubusercontent.com/node-on-fhir/core/main/npmPackages/hipaa-compliance/lib/HipaaLogger.js>

¹⁵ raw.githubusercontent.com

<https://raw.githubusercontent.com/node-on-fhir/core/main/npmPackages/hipaa-compliance/lib/SecurityValidators.js>

¹⁶ raw.githubusercontent.com

<https://raw.githubusercontent.com/node-on-fhir/core/main/npmPackages/hipaa-compliance/lib/EncryptionManager.js>

17 [core/npmPackages/hipaa-compliance/client/policies at main · node-on-fhir/core · GitHub](#)

<https://github.com/node-on-fhir/core/tree/main/npmPackages/hipaa-compliance/client/policies>

18 [eCFR :: 45 CFR 164.316 -- Policies and procedures and documentation requirements.](#)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.316>

23 [raw.githubusercontent.com](#)

<https://raw.githubusercontent.com/node-on-fhir/core/main/imports/lib/extensions/SessionExtensions.js>

24 [eCFR :: 45 CFR 164.530 -- Administrative requirements.](#)

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-E/section-164.530>

28 [170.315\(d\)\(7\) End-user device encryption](#)

https://healthit.gov/test-method/end-user-device-encryption/?utm_source=chatgpt.com

29 [raw.githubusercontent.com](#)

<https://raw.githubusercontent.com/node-on-fhir/core/main/npmPackages/hipaa-compliance/server/policyMethods.js>

30 [45 CFR 170.315 -- ONC certification criteria for Health IT.](#)

https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-D/part-170/subpart-C/section-170.315?utm_source=chatgpt.com